Monthly Intelligence Dispatch

January 2019

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly overview of Group IB, an international company specialising in the prevention of cyber threats and the development of information security products. The purpose of the Dispatch is to inform readers of current cyber threats, attacks by criminal groups, leaks, and new malware. The report includes news of arrests and legal action against members of hacker groups, as well as short-term forecasts and warnings that will help you take timely measures to protect yourself against cyber threats. Group-IB's MTID is prepared for in-house use only and is not intended for distribution.

Key findings

- In January 2019, the threat actor Silence carried out several large-scale attacks on Russian and international financial institutions.
- The Iranian group APT39 is actively conducting large-scale cyberespionage campaigns in the Middle East, the United States and South Korea.
- McAfee linked the Operation Sharpshooter cyber espionage campaign to North Korean hackers.
- On January 23, the threat actor Cobalt sent out emails from a mail server owned by the Indian Punjab & Sind Bank, whose infrastructure was allegedly compromised.
- A new type of cyberattack through the SS7 protocol was first used against Metro Bank. The perpetrators took advantage of the weakness of the SS7 protocol to bypass authentication.
- Group-IB specialists analysed the campaign to plant credit card sniffers into online stores to steal users' bank card data.
- The new NRSMiner cryptominer associated with the NSA EternalBlue Exploit infects users in southern Asia, and most of its victims are in Vietnam.
- Hackers started selling a new malware for Wincor/Diebold ATMs called HelloWorld on their forums.
- Bulgaria extradited Russian hacker Alexander Zhukov to the United States. He was charged by U.S. authorities with advertising fraud and using malicious software to compromise computer networks.
- British hacker Daniel Kay was sentenced to 32 months in prison for attacking telecommunications companies in Liberia in 2016.

Silence

The threat actor Silence is becoming one of the most dangerous Russian-speaking hacking groups, along with Cobalt and MoneyTaker. Over the past six months, the hackers have carried out several large-scale attacks on financial institutions. The cybercriminals were not on vacation in early 2019, either: On **January 4**, Silence sent out phishing emails with a valid signature by SEVA MEDICAL LTD, a UK medical company. On **January 16**, a large-scale attack was detected. It affected more than **80,000** recipients in Russia – employees of Russian financial institutions. In a first for Silence, the malicious attachment was disguised as an invitation to the international forum iFin-2019. This method is often used by state-sponsored hacker groups specializing in espionage.

Since the beginning of summer 2018, Silence has conducted several major phishing campaigns. In June, August and September 2018, the cybercriminals sent out malicious emails purporting to be from ING Bank, Commerzbank and UniCredit bank. On **9 June 2018**, they sent phishing emails purporting to be from ING Bank. Two months later, on **August 11**, the hackers sent "phishes" purporting to be from Commerzbank. On **September 19**, Silence conducted another mass malicious email campaign disguised as letters from UniCredit Bank.

One of the attacks seems to have been successful. In January 2019, during research on the Proxy Bot malware which was uploaded to VirusTotal in January 2019, Group-IB experts discovered the credentials of the network administrator of the Indian bank IndusInd. They were compromised as a result of the attack in August 2018.

Silence is an active and extremely small hacking group consisting of Russian-speaking hackers. The report “Silence: Moving into the darkside” was released in September 2018 and describes the group's tactics and tools for the first time. Activity by this group was first detected by Group-IB specialists in 2016. Silence attacked ATM control systems, card processing and the Russian interbank transfer system– AWS CBR (Automated Work Station Client of the Russian Central Bank). The hackers mainly target Russia, Ukraine, Belarus, Azerbaijan, Poland and Kazakhstan, although phishing emails were also sent to employees of banks in Central and Western Europe, Africa and Asia. The geography of the group's targets is rapidly expanding.

APT39	According to a FireEye report, the Iranian-affiliated APT39 group is carrying out active cyberespionage campaigns in the Middle East, the US, and South Korea. Most of the targets are IT companies, governments, and the telecommunications and tourism industries. The hackers use backdoors such as SEAWEED, CACHEMONEY and a unique version of POWBAT. APT39 has been active since **November 2014**. In parallel, FireEye security experts unveiled a DNS hijacking campaign targeting government agencies, Internet providers and Internet infrastructure facilities in the Middle East, North Africa, North America and Europe. According to the experts, the campaign is being conducted by APT groups affiliated with the Iranian government. FireEye researchers tracked access from Iranian IP addresses to machines used to intercept, record and forward network traffic. These same IPs were previously used in cyberattacks conducted by Iranian cyberspies. Experts claim they monitored hackers from January 2017 to January 2019, but this campaign differs from other phishing attacks conducted by Iranian APTs in that it used DNS interception.
GreyEnergy	Researchers at Kaspersky Lab detected a link between the GreyEnergy malware and the Zebrocy tool. GreyEnergy APT, which is considered by experts from the Kaspersky Lab to be the successor of the BlackEnergy group, conducts intelligence and cyber-espionage activities in Ukraine and Poland, focusing on the energy and transport sectors. The targets of Zebrocy are government institutions spread widely throughout the Middle East, Europe and Asia. Through analysis of a malware sample in early January, researchers found similarities to the infamous BlackEnergy malware, used to attack the Ukrainian energy industry in 2015.

Major events: espionage, sabotage, leaks

Lazarus

At the beginning of the year, McAfee experts detected the cyber espionage campaign Operation Sharpshooter, targeting 87 organizations in global defence and critical infrastructure around the world. In particular it focused on nuclear and energy-related targets, defence facilities, and financial institutions. Experts found numerous similarities between the malware used in Operation Sharpshooter and the 2014 hacking of Sony Pictures by the North Korean group Lazarus. There were similarities in the tools, tactics and procedures used by the threat actor in 2018 and 2014. That said, experts don't rule out that the hackers behind Operation Sharpshooter could be using false flags to complicate attribution.

Details of the attack on the Defence Acquisition Program Administration of the Ministry of National Defence of the Republic of Korea were revealed. **30 computers** were attacked, and 10 of them had internal data leaks. The Defence Procurement Program Administration is responsible for tenders and the procurement of weapons, such as new-generation fighter jets. The invasion was detected on **October 26**, when the National Intelligence Service noticed suspicious IP traffic related to the Agency. However, reports of this incident reached the press only at the beginning of the year.

DarkHydrus

On January 9, experts from the 360 Threat Intelligence Center (TIC 360) detected new attacks by the APT DarkHydrus group (also known as Lazy Meerkat), which used a new version of the Trojan RogueRobin and Google Drive as an alternative channel for C&C. DarkHydrus was first detected by Palo Alto Networks experts in July 2018, when the hackers carried out attacks targeting a government agency in the Middle East.

Major events: attacks on banks

Cobalt

On **January 23**, the threat actor Cobalt sent out emails from a mail server owned by the Indian Punjab & Sind Bank, whose infrastructure was allegedly compromised. The Cobalt group was active throughout December. On **December 6**, Cobalt organized a mass malicious email campaign from the server of the compromised commercial bank "Kassa Nova" (Kazakhstan), and on **December 14** sent out emails to banks which purported to be from the Central Bank of Kazakhstan. On **December 18** they carried out a new attack on financial institutions in America. Throughout 2018, Cobalt remained the most aggressive and active threat actor. According to Europol, at the beginning of 2018, the group stole about **1 billion euros** from **100** banks in **40** countries. The Group-IB forensics team was among the first to investigate Cobalt's attacks on Russian and foreign banks. The Cobalt phishing campaign even reached banks in Australia and Japan. Despite the arrest of a Cobalt leader in the Spanish city of Alicante this spring, attacks on financial institutions continue.

SS7

A new type of cyberattack using SS7 was first used against Metro Bank. The threat actor took advantage of a lack of the SS7 protocol to bypass the 2FA authentication which Metro Bank uses to protect its clients – specifically, to intercept SMS codes sent to clients to authorize transactions.
Signalling System No. 7 (SS7) is a set of telephony signalling protocols developed in **1975**, which is used to set up and tear down telephone calls in most parts of the world-wide public switched telephone network (PSTN and PLMN). SS7 is based on the use of analogue or digital channels for the transmission of data and related control information. At the end of 2018, Group-IB experts conducted an investigation looking for working services that make it possible to intercept victims' calls and SMS messages through the SS7 protocol. Vulnerability in the SS7 protocol is fundamental and will not be eliminated until telecommunications companies around the world accept and put into operation a new protocol for the transfer of service information. Until then, attackers will be able to wiretap and intercept messages.

Major events: sniffers

ImageID	Group-IB experts analysed the activity of ImageID – one of the most widely used families of sniffers in attacks on online shopping sites. During its existence, the sniffer has been improved several times by its developer, and has a number of advantages over other sniffers. After infecting a site, this sniffer works as a keylogger, sending data to the server every time a user makes a change in the payment form on an infected site. The earliest domain names related to this sniffer family were registered at the end of **2017**, which may indicate the start of the main campaign during this period. The targets are websites running on Magento, OpenCart, Shopify, WooCommerce, and WordPress.
TokenLogin	At the same time, Group-IB experts analysed a campaign planting the TokenLogin credit card sniffer into online store sites to steal users' bank card data. Campaign analysis showed that the first infected sites were detected in mid-**2016**. The first domain associated with the administrative panel of this family of sniffers was registered on **March 31, 2016**. In one of the administrative panels of this sniffer, the time of modification of files is April 2016, which may indicate the emergence of this family of sniffers during this period. The TokenLogin credit card sniffer was detected in the code of online stores running CMS and platforms such as Magento, Shopify and Bigcommerce. The sniffer is written using **jQuery.** The principle of its operation is to collect the data entered by the user in the form of payment on the infected site of the online store, and send this user payment information to a server controlled by the hackers.
TokenMSN	Group-IB also analysed a malicious campaign targeted at bank card data theft from online store customers using a family of credit card sniffers called TokenMSN. The main campaign for this sniffer family began in mid-2017, but some copies date back to mid-2016. These attacks were carried out on sites running CMS Magento. As part of this campaign, the threat actor launched a series of attacks to penetrate into web sites with malicious code that stole user payment data. This family of JavaScript sniffers is supposed to be an updated or modified version of the TokenLogin sniffer family described earlier. The main difference of this version is the way the malicious code is executed on the site: in this case, the malicious script is connected to a third-party site and often included as part of legitimate code such as web analytics systems.

Major events: ransomware and cryptominers

Ryuk	FireEye and CrowdStrike have discovered that not only North Korean hackers from Lazarus APT, but also TrickBot operators, use Ryuk ransomware. Experts from Crowdstrike claim that the Ryuk ransomware is controlled by a criminal group they track as GRIM SPIDER, and in particular its Russian cell called WIZARD SPIDER, which is behind TrickBot. Ryuk ransomware was first detected in August 2018 by security experts from Check Point. The virus attacked factories and encrypted hundreds of computers, storage and data centres in each infected factory. The amount of ransom paid by the victims ranged from 15 BTC to 50 BTC. According to various estimates, the attackers have already received more than $640,000.
Ransomware	On January 10, dozens of computers in the City Hall of Del Rio (USA) were infected with a ransomware. The message displayed to users contains a telephone number that can be used to contact the threat actors and receive instructions on how to pay the ransom. In response, the city's MIS (Management Information Services) department first disconnected the infected PCs and then the servers from the Internet. As a result, the work of all city departments was paralysed.
NRSMiner	The new NRSMiner cryptominer connected to the NSA EternalBlue Exploit infects users in southern Asia, and the majority of its victims are in Vietnam (54%), Iran (16%) and Malaysia (12%). EternalBlue, sometimes stylized as ETERNALBLUE, is an exploit developed by the U.S. National Security Agency (NSA) according to testimony by former NSA employees. It was leaked by the Shadow Brokers hacker group on April 14, 2017, and was used as part of the worldwide WannaCry ransomware attack on May 12, 2017. Since mid-November 2018, according to F-Secure telemetry reports, the latest version of the NRSMiner using the Eternal Blue exploit is being actively distributed in Asia. Most of the infected systems seen are in Vietnam.
CookieMiner	Researchers at Palo Alto Networks detected malware for Mac called CookieMiner, which steals cookies related to the Binance, Coinbase, Poloniex, Bittrex, Bitstamp and MyEtherWallet cryptocurrency exchanges and wallets. CookieMiner downloads a Python script named *harmlesslittlecode.py* to extract saved login credentials and credit card information from Chrome's local data storage.

HelloWorld

On January 11th, the user Gookee published an announcement on the sale of new malware for Wincor/Diebold ATMs called HelloWorld on the exploit.in forum. The program is sold in the following versions: an executable file, an IMG image for writing to a flash drive, a CD image, a floppy disk and an ISO image. The cost of the program is $**2,000** per .EXE file or image. HelloWorld is a modification of the famous Cutlet Maker, but according to the author, it has the following advantages: this malware doesn't need a keyboard to dispense cash, the program cleans up its traces and its size is 60 KB. As we reported earlier, in the spring of 2018, hacker forums had offers to sell the Trojan Cutlet v.2 for attacking Wincor ATMs at a price of $5000, including the source code, documentation and instructions for use.

BMW

The malicious program BMW (Hidden VNC type), developed by a threat actor with the nickname "BMWteame", has appeared on a hacker forum. This program allows its users to gain hidden remote access to a victim's computer and is able to download other malicious programs. The program works on Windows systems from 7 to 10. The cost of renting the program is $**1,500** per month, and the license price is $**4,500**. The seller prohibits BMW work in the territory of the CIS. Beginning in November 2018, BMWteame was looking for a development team to create HVNC. They then suspended recruitment in December, and began to look for developers again in January due to expansion. Due to the expansion of the BMW creators' development team, there is a high probability of a new product from BMWteame appearing on the underground market.

Anubis

Group-IB specialists analysed samples of a bank Trojan for Android called Anubis, which was developed by a Russian-speaking virus writer called "maza-in". This Trojan is distributed through **Google Play**, using lightweight loader applications that are not detected by antivirus solutions and are masked as legitimate software. After installation the Trojan downloads the Anubis payload and installs it, masquerading it as, for example, "Flash Player" or "Google Play Protect". The application can intercept SMS messages, show web fakes, make various USSD requests, encrypt data on the device, intercept keystrokes, and so on. Curiously, there's no topic about selling this Trojan in underground forums. Potential customers receive detailed information about the bank Trojan by contacting the author of the threat through personal messages on underground forums.

Arrests and sentencing

Zhukov

January 18, Bulgaria extradited the Russian hacker Alexander Zhukov to the United States. He was charged by U.S. authorities with advertising fraud and the use of malicious software to compromise computer networks. It is worth remembering that in November, U.S. law enforcement agencies and private companies, such as Google and WhiteOps, conducted a large-scale operation which resulted in the dismantling of the threat actor 3ve. 3ve infected more than **1.7** million computers to commit ad fraud such as fake views on YouTube. In particular, the attackers created fake versions of websites and used their own botnet to simulate the actions of visitors, offering ad spots to advertisers and capturing the Border Gateway Protocol to redirect traffic. They also used a special malicious program to advertise online. 3ve started work in 2014, and its activity peaked in 2017, at which point the hackers controlled more than 1 million IP addresses in North America and Europe. During this time the fraudsters may have earned more than $30 million. The U.S. Justice Department has brought charges against 8 citizens from Russia, Kazakhstan and Ukraine, of whom Zhukov is one.

Gottesfeld

American hacktivist and Anonymous member Martin Gottesfeld (aged 34) was sentenced to 10 years in prison for DDoS attacks on Boston Children's Hospital and Wayside Youth and Family Support Network in 2014. Gottesfeld published a YouTube video calling on anonymous hackers to support the start of a cyberattack on Boston Children's Hospital, asking to return Justina Pelletier to her parents. He himself used a botnet of more than 40,000 malware-infected network routers. According to Boston Hospital, the attack caused losses of more than $300,000, as well as paralysing the website used to collect donations, which resulted in additional damage.

Kaye

British hacker Daniel Kaye was sentenced to 32 months in prison for an attack on telecommunications companies in Liberia in 2016. The court determined that an employee of a rival Cellcom company paid Kaye £**7,800** per month for a DDoS attack on the Liberian telephone and Internet service provider Lonestar. Daniel Kaye admitted that his DDoS attack with the "Mirai #14" botnet consisting of Chinese Dahua web cams almost isolated Liberia from the Internet.

Arrests and sentencing

Joel Ortiz

Student Joel Ortiz was sentenced to 10 years in prison for SIM-card "hijacking" and theft of crypto-currency worth **$5 million**. At least **40** victims were involved. The scheme was as follows: First, the threat actor collected complete data about the victims by launching a phishing campaign or buying data on hacker forms. Then hackers addressed the telecommunications provider and asked to be re-issued a SIM-card, posing as another person. After receiving a new SIM card, the fraudsters could work with the victim's mobile account, intercept or initiate calls, access SMS messages (including authorization codes sent by banks and cryptocurrency exchanges) and authorize transactions. Joel Ortiz is the first hacker to be sentenced to prison for "hijacking" a SIM card.

G0d

A 20-year-old hacker from Germany was arrested for a recent massive data leak that affected hundreds of German politicians, including members of the lower house of parliament in the Bundestag, the European Parliament, and deputies from all parties, regional and local assemblies. Disclosed data includes email addresses, mobile phone numbers, invoices, copies of ID documents and personal chat logs. The data was published on Twitter on the "G0d" account (@_0rbit), and the hacker was charged with espionage and illegal publication of personal data. In response, the defendant said he had published the data because he was irritated by some of the statements made by the victims.

xDedic

Law enforcement agencies in the USA and Europe announced the capture of the popular underground market xDedic, which sold access to compromised systems and personal data. The resource has been active since 2014, with possible revenues of $**68 million**. In 2016, the service offered up to 70,000 hacked servers. Researchers believe that the xDedic market was managed by a Russian-speaking group.

Forecasts and warnings

- Having gained the necessary experience to conduct targeted attacks on banks in Russia, the Silence group began to successfully apply its skills to attacking international companies, actively preparing infrastructure and testing new tools. The attack on the bank in India is just the beginning of the global expansion of Silence.
- Despite the arrest of a Cobalt leader in the Spanish city of Alicante in the spring on 2018, attacks on financial institutions continue.
- Due to the expansion of the BMW creator's development team, there is a high probability of a new product from BMWteame appearing on the underground market.
- The successful attack on Metro Bank using a vulnerability in the SS7 protocol will not be the last, until telecommunications companies around the world accept and put into operation a new protocol for transferring service data. Until then, attackers will be able to wiretap and intercept messages.
- The new Anubis banking Trojan uses lightweight loaders that are not detected by antivirus solutions and are disguised as legitimate software.

If you would like to receive more detailed information about a specific incident, threat, or criminal group, please contact us.

We are able to conduct investigations that provide you with the maximum intelligence on threats targeting your organisation.

+ 1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com